

EX:09

Compliance Assessments - Test of Design and Test of Operational Effectiveness

Aim

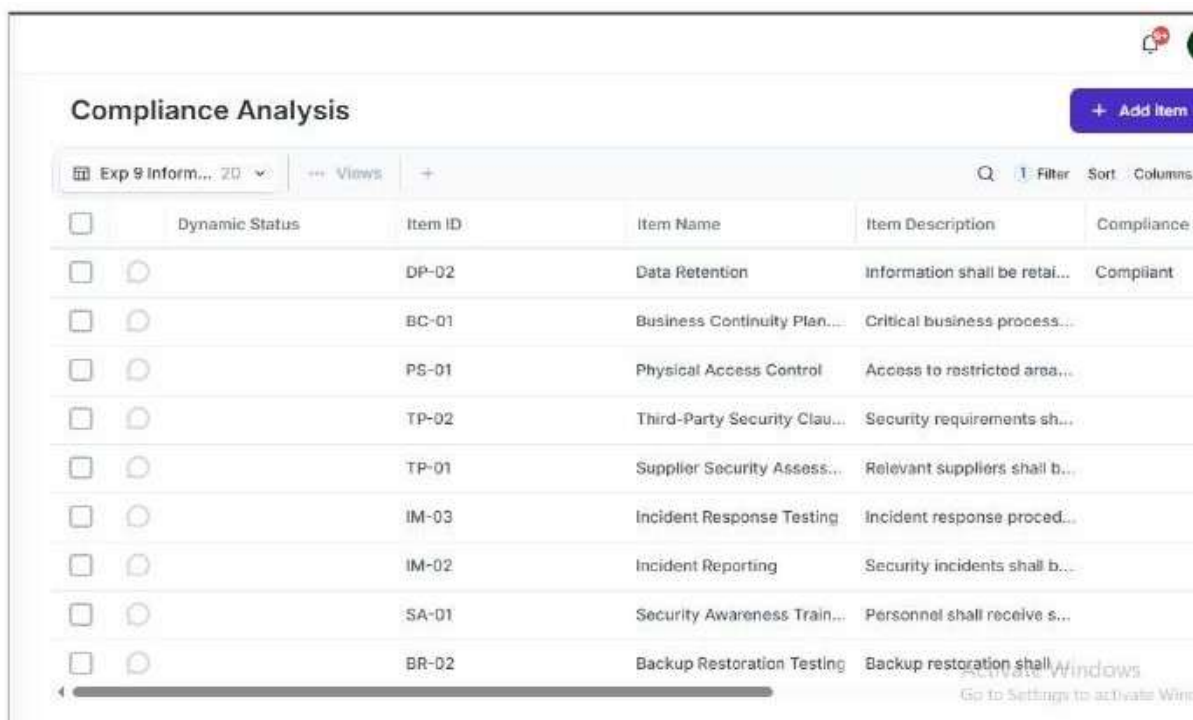
To evaluate a compliance requirement in Eramba through Test of Design (ToD) and Test of Operational Effectiveness (ToOE), while connecting the assessment to supporting controls, policies, and business risks.

Procedure

1. Open Compliance Management → Compliance Packages.
2. Create the AsterByte Security Compliance Review package and add a compliance requirement for access authentication.
3. Open Compliance Management → Compliance Analysis and select the created requirement.
4. Set the compliance strategy to Compliant and assign the responsible owner.
5. Link the relevant internal control, policy, and Cloud Service Availability Risk.
6. Document the Test of Design to confirm that the requirement is formally defined.
7. Document the Test of Operational Effectiveness to confirm that the related control operates and supporting evidence is available.
8. Save the assessment and review the resulting compliance information.

Output

A compliance requirement was assessed with a compliance strategy, owner, supporting GRC relationships, and documented ToD and ToOE checks.



The screenshot displays the 'Compliance Analysis' section of a software interface. It features a table with columns for 'Dynamic Status', 'Item ID', 'Item Name', 'Item Description', and 'Compliance S'. The table lists several requirements, each with a checkbox and a status indicator (a circle with a dot). The requirements include Data Retention, Business Continuity Plan, Physical Access Control, Third-Party Security Clau, Supplier Security Assess, Incident Response Testing, Incident Reporting, Security Awareness Train, and Backup Restoration Testing. A purple '+ Add Item' button is visible in the top right corner. The bottom of the image shows a Windows taskbar with the 'Activate Windows' watermark and a message to 'Go to Settings to activate Windows'.

Dynamic Status	Item ID	Item Name	Item Description	Compliance S
☐	DP-02	Data Retention	Information shall be retai...	Compliant
☐	BC-01	Business Continuity Plan...	Critical business process...	
☐	PS-01	Physical Access Control	Access to restricted area...	
☐	TP-02	Third-Party Security Clau...	Security requirements sh...	
☐	TP-01	Supplier Security Assess...	Relevant suppliers shall b...	
☐	IM-03	Incident Response Testing	Incident response proced...	
☐	IM-02	Incident Reporting	Security incidents shall b...	
☐	SA-01	Security Awareness Train...	Personnel shall receive s...	
☐	BR-02	Backup Restoration Testing	Backup restoration shall	

Fig 9.1 - Compliance Analysis Requirements List

Item detail

Compliance Item Details	
Item ID	DP-02
Item Name	Data Retention
Item Description	Information shall be retained and securely disposed of according to defined requirements.
Item Additional Information	ToD: Verify retention and disposal requirements are documented ToOE: Review retention records and disposal evidence.
General	
Dynamic Status	
Compliance Strategy	Compliant

Fig 9.2 - Compliance Requirement Details

Treatment	
Internal Controls	Backup and Recovery Firewall Management
Policies	Access Control Policy Password Policy
Compliance Exception	
Projects	
Risks	
Asset Risks	
Third Party Risks	
Business Risks	Data Breach Unauthorized Access

Fig 9.3 - Treatment and Risk Relationships

Result

The compliance assessment workflow was successfully configured in Eramba. The requirement can be evaluated for both design adequacy and operating effectiveness while remaining linked to supporting GRC records.